SECURITY

ELEVATED

API KEY LEAKED TO GITHUB

A developer accidentally committed live production credentials to a public repository. Automated bots scan GitHub continuously for exactly this. The window between commit and exploit is measured in seconds — not hours.

Secrets committed to version control are one of the most preventable and most common security incidents. The correct response is immediate credential rotation — not deletion of the commit, which is insufficient since Git history and forks persist. Prevention requires: pre-commit hooks that scan for secrets before they are committed (tools like git-secrets, truffleHog, or GitGuardian), CI pipeline secret scanning on every push, secrets management platforms (HashiCorp Vault, AWS Secrets Manager) so credentials are never stored in code or environment files, and developer training. The key DevOps principle is 'shift left' — catch this class of error before it ever reaches the repository.

Secrets don't belong in code. They never did. Secret scanning in CI is a five-minute setup with zero downside.

TEAM DISCUSSION

How quickly can you rotate all affected credentials? Do you know every place each key is used?